



INTELLIGENCE PASSIVA SUL DOMINIO

example.com

Il dominio è raggiungibile. Mancano 2 header di sicurezza osservabili.

Generato: 2026-07-05T00:00:00+00:00

Analista: OSINTPRO Analyst

82/100

PUNTEGGIO SICUREZZA

1

IP RISOLTI

2

FINDING

Sintesi dello scope

- **Postura email: 60/100.** Sono stati osservati servizio mail o record di autenticazione email.
- **HTTPS Stato: 200; certificato in scadenza Aug 29 21:41:26 2026 GMT.**
- **Metadati pubblici di indicizzazione: robots.txt non pubblicato, sitemap.xml non pubblicato.** La pubblicazione non è una vulnerabilità di per sé.

Azioni prioritarie

- **Aggiungi o rivedi gli header di sicurezza mancanti: content-security-policy.**

Finding prioritari

I finding sono osservazioni passive e ipotesi di revisione. Valida l'impatto in un ambiente autorizzato prima di presentarli come vulnerabilità confermate.

MEDIA

Header di sicurezza mancante

Segnale pubblico da verificare nel contesto autorizzato del proprietario.

COME POTREBBE ABUSARNE UN ATTACCANTE

Un attaccante potrebbe combinarlo con altre debolezze osservabili per aumentare impersonificazione, abuso o confusione operativa.

IMPATTO BUSINESS

Il rischio principale è ritardo di risposta, perdita di fiducia, abuso del brand o esposizione di dati se esistono altre condizioni vulnerabili.

AZIONE PER IL PROPRIETARIO

Assegna un owner tecnico, valida la configurazione corrente, pianifica la correzione e aggiungi un controllo di regressione.

EVIDENZE DA RACCOGLIERE

Raccogli record pubblici, owner del servizio, log disponibili, screenshot e note di approvazione del remediation plan.

MEDIA

Superficie XSS potenzialmente più ampia

Content-Security-Policy non osservata nella risposta HTTPS principale.

COME POTREBBE ABUSARNE UN ATTACCANTE

If an input-handling bug exists, the absence of CSP gives an attacker more room.

IMPATTO BUSINESS

Session abuse or sensitive page content exposure.

AZIONE PER IL PROPRIETARIO

Valida con test applicativi autorizzati e definisci una CSP per script, frame e connect-src.

EVIDENZE DA RACCOGLIERE

Distribuisci prima una CSP report-only, poi applicala.

DNS e infrastruttura

- IP risolto: 203.0.113.10
- Nameserver: ns1.example.com
- Mail exchange: 10 mail.example.com
- CAA: non osservato

TLS e controlli browser

Subject certificato: CN=example.com. Scadenza: Aug 29 21:41:26 2026 GMT.

- Mancante - content-security-policy: Header non trovato nella risposta HTTPS
- OK - x-frame-options: DENY

Email e metadati pubblici

Sono stati osservati servizio mail o record di autenticazione email.

robots.txt and sitemap.xml are expected indexing metadata. Their presence is not a vulnerability unless sensitive paths are disclosed.

Metodologia e limiti

OSINTPRO ha raccolto segnali pubblici passivi da DNS, risposte HTTPS, metadati dei certificati, Certificate Transparency e risorse well-known pubbliche. Non ha eseguito exploit, brute force, scansioni di reti private o tentativi di modifica del target.

Regole di interpretazione

- **I controlli email mancanti sono finding solo quando si osserva un servizio mail o una policy email.**
- **robots.txt e sitemap.xml sono metadati pubblici attesi e non sono vulnerabilità di per sé.**
- **OpenID, file di associazione mobile e BIMl sono opzionali salvo claim espliciti del prodotto.**
- **I segnali CNAME takeover richiedono validazione di proprietà; un CNAME verso provider gestito non prova exploitabilità.**
- **Certificate Transparency e una fonte di scoperta asset e monitoraggio, non una vulnerabilità.**

Confine passivo

Questo report è evidenza per revisione difensiva, non prova di identità, compromissione o exploitabilità. I finding devono essere confermati dal proprietario asset o da un professionista autorizzato.